

Online Egitim Platformu

Guvenlik Acik Raporu ve Iyilestirme Onerileri

Hazirlayan: Zbyr21 | Tarih: Mayis 2026 | Branch: security/full-hardening-sprint

1. Yonetici Ozeti (Executive Summary)

Bu rapor, Online Egitim Platformu'nun backend (Node.js/Express/MongoDB) ve frontend (React/Vite) katmanlarinda yurutulen kapsamli guvenlik denetiminin bulgularini, risk degerlendirilmelerini ve somut iyilestirme onerilerini icerir. Denetim, kod inceleme, mimari analiz ve bagimlilik taramasi yontemleriyle gerceklestirilmistir.

Sprint oncesi durumla karsilastirildiginda platforma Helmet, CORS, Rate Limiting, JWT kimlik dogrulama, bcrypt sifre hashleme ve Joi giris dogrulama gibi kritik guvenlik katmanlari eklenmistir. Bununla birlikte bazi orta ve dusuk oncelikli riskler hala dikkate alınmasi gereken iyilestirme alanlari olarak tespit edilmistir.

2. Denetim Kapsam

- Backend: Node.js v24, Express v4, Mongoose v8, JWT, bcryptjs, Helmet, express-rate-limit
- Frontend: React 18, Vite 6, eslint
- Veritabani: MongoDB (Mongoose ODM)
- Kimlik Dogrulama: JWT (Bearer token), bcryptjs parola hashleme
- Dogrulama: Joi schema validation, express-mongo-sanitize
- Guvenlik Basliklar: Helmet v8, CORS (whitelist tabanlı)
- Hiz Siniri: Global (100 istek/15dk), Auth (20 istek/15dk)
- Hata Yonetimi: Merkezi errorHandler, AppError sinifi, Winston loglama

3. Guvenlik Bulgulari ve Risk Degerlendirmesi

3.1 JWT Token Yenileme Mekanizmasi Eksikligi

ORTA RISK

Sorun: Auth middleware yalnızca erişim tokeni (access token) kullanmakta; yenileme tokeni (refresh token) mekanizması bulunmamaktadır. JWT_EXPIRES_IN varsayılan değeri "7d" olarak ayarlanmıştır.

Tehlike: Bir token alındığı takdirde 7 gün boyunca geçerliliği devam eder; iptal mekanizması yoktur.

Oneri: Kısaltılmış erişim tokeni (15-60 dk) + refresh token (HttpOnly cookie) ikili yapısı uygulanmalı; token kara listesi (Redis) veya jti claim ile iptal desteklenmeli.

3.2 HTTPS / TLS Zorlamasi Eksik

ORTA RISK

Sorun: Uygulama HTTP üzerinden çalışabilmekte; HTTPS yönlendirmesi veya HSTS başlığının alt katmanda uygulanmasını zorlayan bir mekanizma bulunmamaktadır.

Tehlike: Oturum tokenleri ve kullanıcı bilgileri ağ dinleme (MITM) saldırılarına maruz kalabilir.

Oneri: Üretim ortamında ters proxy (Nginx/Caddy) katmanında TLS sonlandırması yapılmalı; Helmet içerisindeki HSTS secenegi etkinleştirilmeli (helmet({ hsts: { maxAge: 31536000 } })).

3.3 Rol Tabanlı Erisim Kontrolu (RBAC) Kismen Uygulanmis

ORTA RISK

Sorun: Kullanıcı kaydı sırasında rol (role) alanı istek gövdesinden alınmaktadır (req.body.role). Joi

schema'da gecerli roller "student" ve "teacher" ile sinirlendirilmis olsa da admin rolu ilerde eklenirse bu kontrol yeterli olmayabilir.

Tehlike: Privilege escalation: Bir saldirgan, schema'yi atlayan farkli bir yontemle yuksek yetkili rol talep edebilir.

Oneri: Rol atamasini istek govdesinden degil sunucu taraflı is mantigindan belirlenmeli. Yeni kullanıcılara varsayılan olarak "student" atanmalı; ogretmen veya yönetici rolleri yalnızca yetkili bir admin endpoint'i üzerinden verilmeli.

3.4 Parola Guc Politikasi Temel Duzeyde

DUSUK-ORTA RISK

Sorun: Joi schema parolayı en az 8 karakter ve en fazla 128 karakter olarak dogrulamaktadır; ancak büyük/küçük harf, rakam veya özel karakter karmaşıklık kuralları uygulanmamaktadır.

Tehlike: "12345678" gibi basit parolalar kabul edilir; brute-force saldırısına dirençsizdir.

Oneri: Joi pattern() ile en az bir büyük harf, bir rakam ve bir özel karakter zorunlu kılınmalı. Alternatif olarak zxcvbn kutuphanesi ile parola gucu skoru (≥ 3) şartları uygulanabilir.

3.5 Hassas Veri Loglama Riski

DUSUK-ORTA RISK

Sorun: Winston logger "combined" formatında HTTP isteklerini kaydetmektedir. Morgan kombinasyonu, Authorization başlığını veya istek govdesini yanlış konfigürasyonda loglayabilir.

Tehlike: Log dosyalarında JWT token veya parola kalıntısı bulunabilir; log inject saldırısı gerçekleştirilebilir.

Oneri: Morgan stream konfigürasyonunda Authorization ve Cookie başlıklarını maskeleyme (redact) uygulanmalı. Winston'da log seviyesi üretimde "warn" veya üzeri olacak şekilde ayarlanmalı.

3.6 JSON Istek Boyutu (50 KB) Sabit Kodlanmış

DUSUK RISK

Sorun: `express.json({ limit: '50kb' })` ile istek büyüklüğü sınırlanmıştır; ancak bu değer ortam değişkeni yerine sabit kodlanmıştır.

Oneri: Bu limit çevresel konfigürasyona (env) taşınmalı: `express.json({ limit: env.jsonBodyLimit || '50kb' })`.

3.7 Vite Bagimlilik Yuksek Guvenlik Acigi (Frontend)

YUKSEK RISK

Sorun: Frontend paketlerinde Vite v8.0.0 kullanılmaktadır. Bu sürüm Path Traversal ve Arbitrary File Read CVE güvenlik açıkları içermektedir.

Tehlike: Geliştirme ortamında yerel dosya sistemi okunabilir; üretim build pipeline'ini etkiler.

Oneri: frontend/ klasöründe "npm audit fix" çalıştırılarak Vite v8.0.4+ sürümüne güncellenmeli. Gelecekte CI pipeline'a "npm audit --audit-level=high" eklenmelidir.

3.8 Test Suiti Eksikligi

MIMARI RISK

Sorun: package.json'da Jest ve Supertest bağımlılık olarak eklenmiş ancak herhangi bir test dosyası bulunmamaktadır.

Tehlike: Güvenlik düzenlemelerinin doğruluğunu otomatik kontrol eden mekanizma yok; regresyon riski yüksek.

Oneri: Öncelikle auth ve users endpoint'leri için entegrasyon testleri yazılmalı. Her PR'da CI'da "npm test" koşulmalı.

4. İyi Uygulanan Guvenlik Onlemleri

OK Helmet v8: XSS, Clickjacking, MIME sniffing karşı HTTP güvenlik başlıklar etkin.

OK CORS Whitelist: allowedOrigins ile yalnızca izin verilen originlere yanıt veriliyor.

OK Rate Limiting: Global 100/15dk, Auth 20/15dk; brute-force koruması .F-`.

OK bcryptjs Parola Hashleme: pre('save') hook ile otomatik hash; plaintext depolanmıyor.

OK Joi Schema Doğrulama: Tüm auth endpointlerinde giriş doğrulama ve stripUnknown aktif.

OK express-mongo-sanitize: NoSQL injection karşı \$ ve . karakterleri temizleniyor.

OK JWT Kimlik Dogrulama: RS secret + role claim; authenticate/authorize middleware ayri katmanda.

OK Merkezi Hata Yonetimi: AppError sinifi + errorHandler; stack trace uretimde gizleniyor.

OK Env Dogrulama: JWT_SECRET uzunluk kontrolu; uretimde eksik secret'ta process sonlaniyor.

OK Graceful Shutdown: SIGINT/SIGTERM yakalanarak veritabani baglantisi guvenle kapatiyor.

OK Winston + Daily Rotate: Yap AE æF— ilmis loglama; gunluk log rotasyonu aktif.

OK JSON Body Limiti: 50 KB siniri ile buyuk payload saldirilari engelleniyor.

5. Oncelikli Iyilestirme Plani

YUKSEK ONCELIK (Hemen)

- Frontend bagimlilik acigini kapatmak icin npm audit fix calistir (Vite CVE).
- CI pipeline'a npm audit --audit-level=high ekle; hata durumunda build durdur.
- Auth testleri: register, login, yetkisiz erisim senaryolari icin Supertest testleri yaz.

ORTA ONCELIK (1-2 Hafta)

- Refresh token mimarisi: HttpOnly cookie + Redis kara listesi uygula.
- Uretim HTTPS zorlamasi: Nginx reverse proxy + Let's Encrypt veya Caddy otomatik TLS.
- Rol atama guvenligi: Kayit akisinda rolealani kaldir; varsayilan "student" ata.
- HSTS basligini Helmet yapilandirmasinda acikca etkinlestir.

DUSUK ONCELIK (1 Ay)

- Parola guc politikasi: Joi pattern veya zxcvbn ile karmasiklik kurallari ekle.
- Log redaction: Authorization/Cookie basliklarini maskeleyerek loglama.
- JSON body limitini env degiskenine tasi.
- Bagimlilik guncellemelerini otomatikleştir: Dependabot veya Renovate bot.
- Guvenlik tarali CI asamasi: OWASP Dependency-Check veya Snyk entegre et.

6. Risk Matrisi Ozeti

Bulgu	Olasilik	Etki	Risk Seviyesi
Vite Path Traversal CVE	Yuksek	Dusuk	Kritik
JWT Yenileme Eksikligi	Orta	Orta	Orta
HTTPS / TLS Eksikligi	Orta	Orta	Orta
Rol Atama Guvenligi	Orta	Dusuk	Orta
Parola Guç Politikasi	Orta	Dusuk	Dusuk-Orta
Hassas Veri Loglama	Dusuk	Dusuk	Dusuk
Body Limit Sabit Kodlama	Dusuk	Cok Dusuk	Cok Dusuk
Test Suiti Eksikligi	Mimari	Orta	Orta

7. Gelecekteki Guvenlik Riskleri ve Uzun Vadeli Onlemler

Yetkilendirme Granularitesi (ABAC)

Risk: Platform buyudukce basit rol kontrolu (RBAC) yeterli olmayabilir. Ogrenci baskasinin odevine, ogretmen

baskasinin kursuna eriserek veri sizintisi yasanabilir.

Onlem: Kaynak sahipligi kontrolu ekle (req.user.id === resource.ownerId). Ileri asama icin ABAC (Attribute-Based Access Control) kutuphanesi (casbin.js) degerlendir.

Dosya Yukleme Guvenligi

Risk: Ilerleyen surumde ders materyali veya profil fotograf yukleme ozelligi eklendigi takdirde MIME type spoofing ve depolama yolu gecisine (path traversal) karsi risklere kapi aralanabilir.

Onlem: Multer ile tip dogrulama, magic-bytes kontrolu, UUID tabanli dosya ismi yeniden adlandirma ve dosyalari uygulama dizini disinda (S3, Azure Blob) saklama.

WebSocket / Gercek Zamanli Guvenlik

Risk: Socket.io bagimlilik zaten node_modules'de mevcut. Canli ders ozelliginde kimlik dogrulanmamis WebSocket baglantisi, mesaj enjeksiyonu veya oda yetkisi atlatma riski.

Onlem: Socket.io middleware katmaninda JWT dogrulama; oda yetkilendirme kontrolu.

Konteyner / Altyapi Guvenligi

Risk: Uygulama konteynerize edilirse root kullanıcı ile calisma, sinirlendirilmamis kaynak kullanimi veya gizli ortam degiskenlerinin imajen gommesi gibi riskler olusabilir.

Onlem: Non-root kullanıcı icin Dockerfile duzenlenmeli; Docker Secrets veya Vault ile gizli yonetim; read-only filesystem; resource limit (CPU/ Memory).

Tedarik Zinciri Saldirisi (Supply Chain)

Risk: npm paketleri uzerinden kotu niyetli kod enjeksiyonu (typosquatting, malicious update) giderek artan bir tehdit.

Onlem: package-lock.json commit edilmeli; "npm ci"

kullanilmali; Dependabot/ Renovate ile otomatik guncelleme; Socket.dev veya Snyk ile surekli tedarik zinciri taramasi.

API Versiyonlama ve Deprecation

Risk: Zaman icerisinde eski API versiyonlari bakimsiz kalarak eski guvenlik aciklari barindirabilir.

Onlem: Versiyonlu rota yapisi (/api/v1/...) ve eski endpoint'ler icin sunset politikasi.

8. Sonuc

security/full-hardening-sprint kapsaminda platforma eklenen guvenlik katmanlari (Helmet, CORS whitelist, rate limiting, JWT auth, bcrypt, Joi validation, mongo-sanitize) onceki durumla kiyaslandiginda buyuk bir ilerleme saglamistir. Temel OWASP Top 10 risklerinin buyuk cogunlugu ele alinmistir.

Kalan riskler oncelik sirasina gore ele alindiginda (oncelikle Vite CVE duzeltmesi, ardindan refresh token ve HTTPS, son olarak parola politikasi ve log gizleme) platform uretim ortamina hazir guvenlik olgunuguna ulasacaktır. Duzenli bagimli Á1k taramasi ve otomatik testler, uzun vadeli guvenlik surdurulebilirliigi icin vazgecilmezdir.